WEB APPLICATION VULNERABILITY ASSESSMENT

AND PENETRATION TESTING REPORT

OWASP ZAP – Web Application Security Testing

Project detail	Recorded value
Project	Second Cybersecurity Project – OWASP ZAP
Assessment target	http://testfire.net/login.jsp
Tool	OWASP ZAP (Zed Attack Proxy)
Scan profile	Full Scan
Prepared by	Madisetti Nagaditya Shanmukh
Report type	Educational web application security assessment

CONFIDENTIALITY NOTE

This report is prepared for academic and portfolio purposes. Findings are based on the supplied OWASP ZAP report screenshots and should be validated against the live application before being treated as confirmed exploitable vulnerabilities.

1. Executive Summary

An automated web application security assessment was performed using OWASP ZAP against the login page at http://testfire.net/login.jsp. The supplied scan evidence identifies 16 alerts distributed across the OWASP Top 10 2017 categories in the report's compliance summary. The largest category count is Sensitive Data Exposure (5 alerts), followed by Security Misconfiguration (3), Components with Known Vulnerabilities (3), Broken Access Control (2), and Cross-Site Scripting (2).

The detailed pages show examples including a Blind SQL Injection alert, Cross-Site Scripting alerts, Directory Traversal, missing X-Frame-Options (clickjacking protection), password autocomplete enabled, and broken-link alerts. Some findings appear more than once in the detailed report. Therefore, the 16 figure is the scanner's alert count, not a count of 16 distinct vulnerability types.

Metric	Result
Total alerts in compliance summary	16
Categories with at least one alert	6 of 10
Highest-count category	A3 – Sensitive Data Exposure (5)
Scan profile	Full Scan
Scan duration	33 minutes, 40 seconds

Key observations

- Blind SQL Injection is listed with a CVSS v3 score of 10.0 in the detailed evidence; it requires immediate manual validation and remediation.
- XSS alerts are listed with CVSS v3 score 5.3 in the supplied details.
- Directory Traversal is listed with CVSS v3 score 5.3 in the supplied details.
- The missing X-Frame-Options header is reported as a clickjacking-related configuration issue.
- Several broken-link alerts have a CVSS score of 0.0 and should be treated as availability/content-quality observations, not equivalent to exploitable security flaws.

2. Assessment Scope and Rules

Item	Description
In-scope target	http://testfire.net/login.jsp and pages discovered by the ZAP scan under testfire.net
Assessment approach	Automated web application scan using OWASP ZAP Full Scan profile
Evidence source	Screenshots of the ZAP scan summary, detailed alert pages, affected-items section and coverage report
Out of scope	Infrastructure exploitation, denial-of-service testing, social engineering, credential attacks and any systems not represented in the supplied evidence
Authorization	Use only against systems for which the tester has explicit permission. This report records a learning assessment and does not establish authorization to test other systems.

The supplied evidence identifies the target as testfire.net. The report does not assume that every scanner alert is exploitable. Automated results can include false positives, duplicate instances, informational observations and findings that require manual confirmation.

3. Objectives

- Identify potential web application security weaknesses using OWASP ZAP.
- Review alerts against the OWASP Top 10 categories displayed in the ZAP report.
- Record the available CVSS and CWE metadata for representative findings.
- Document scan coverage and evidence for reproducibility.
- Provide prioritized remediation guidance and recommendations for retesting.

4. Tools and Technologies

Tool / technology	Purpose
Kali Linux	Security testing environment used for the project
OWASP ZAP	Intercepting proxy and automated web application vulnerability scanner
Web browser	Accessing the target application and observing web pages
OWASP Top 10	Risk-category reference used by the supplied report
CVSS	Severity scoring reference shown in the detailed alert records

5. Methodology

1. Prepare the authorized testing environment and open OWASP ZAP.
2. Configure the target application URL: http://testfire.net/login.jsp.
3. Use the ZAP Full Scan profile shown in the evidence.
4. Allow ZAP to discover and scan reachable application resources.
5. Review the Compliance at a Glance summary to record category-level alert counts.
6. Open detailed alert records and note the alert name, CVSS score, CWE mapping and affected item where available.
7. Review the affected-items and scanned-items coverage sections.
8. Group duplicate alert instances carefully and prepare remediation recommendations.
9. Validate important alerts manually before reporting them as confirmed vulnerabilities.

6. Scan Summary and OWASP Category Distribution

The following counts are transcribed from the ZAP report's Compliance at a Glance section. These are category alert counts and may include repeated instances.

OWASP category (as shown in report)	Alerts
A1 Injection	1
A2 Broken Authentication	0
A3 Sensitive Data Exposure	5
A4 XXE	0
A5 Broken Access Control	2
A6 Security Misconfiguration	3
A7 Cross-Site Scripting	2
A8 Insecure Deserialization	0
A9 Components with Known Vulnerabilities	3
A10 Insufficient Logging & Monitoring	0
TOTAL	16

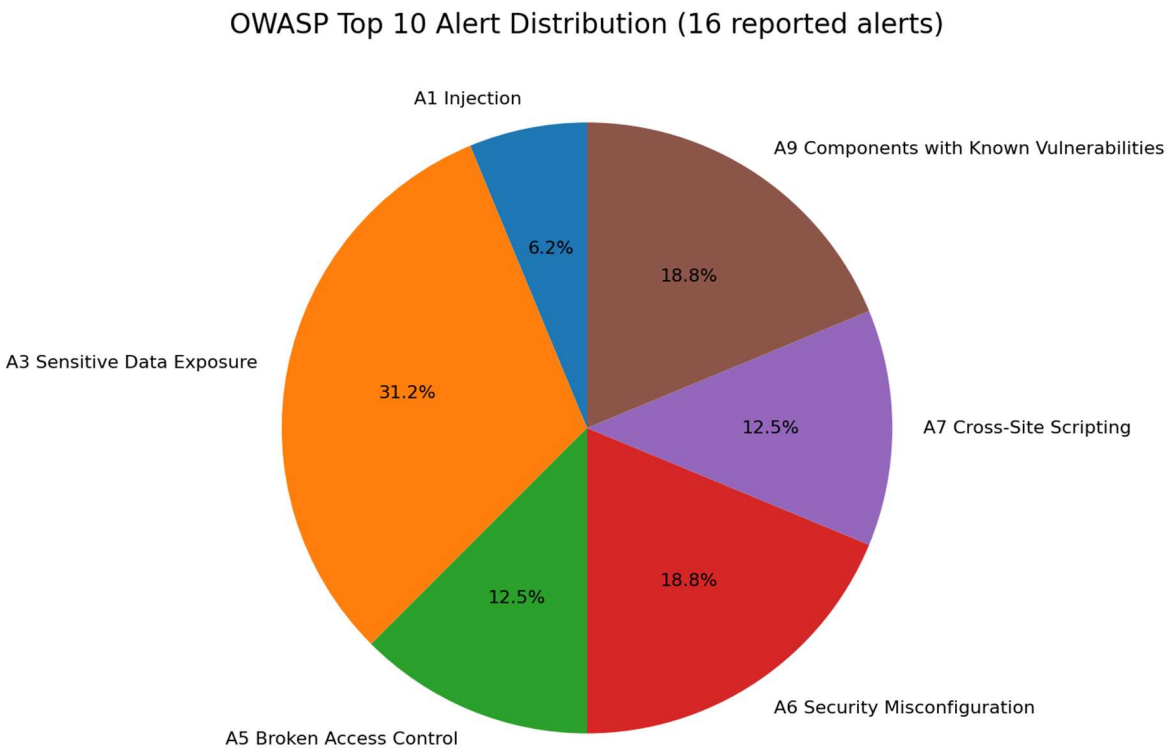


Figure 1. Distribution of the 16 category-level alerts recorded in the supplied ZAP summary.

7. Detailed Findings

The table below consolidates the distinct alert names visible in the supplied detailed screenshots. Where the report does not provide enough evidence to establish exploitability or an exact affected parameter, the limitation is stated rather than inferred.

ID	Finding	Score / severity shown	CWE	Observation	Recommendation
F-01	Blind SQL Injection	Critical – CVSS v3 10.0 shown	CWE-89	Potential database query manipulation; confirm manually in a controlled, authorized test.	Use parameterized queries/prepared statements; validate server-side input; apply least-privilege database accounts; add safe error handling.
F-02	Cross-Site Scripting (XSS)	Medium – CVSS v3 5.3 shown	CWE-79	Untrusted input may be included in generated page output without safe encoding.	Apply context-aware output encoding; validate input; use safe templating; deploy a restrictive Content Security Policy as defense in depth.
F-03	Directory Traversal	Medium – CVSS v3 5.3 shown	CWE-22	ZAP reports a script as possibly vulnerable to directory traversal.	Avoid constructing filesystem paths from raw user input; canonicalize and validate paths;

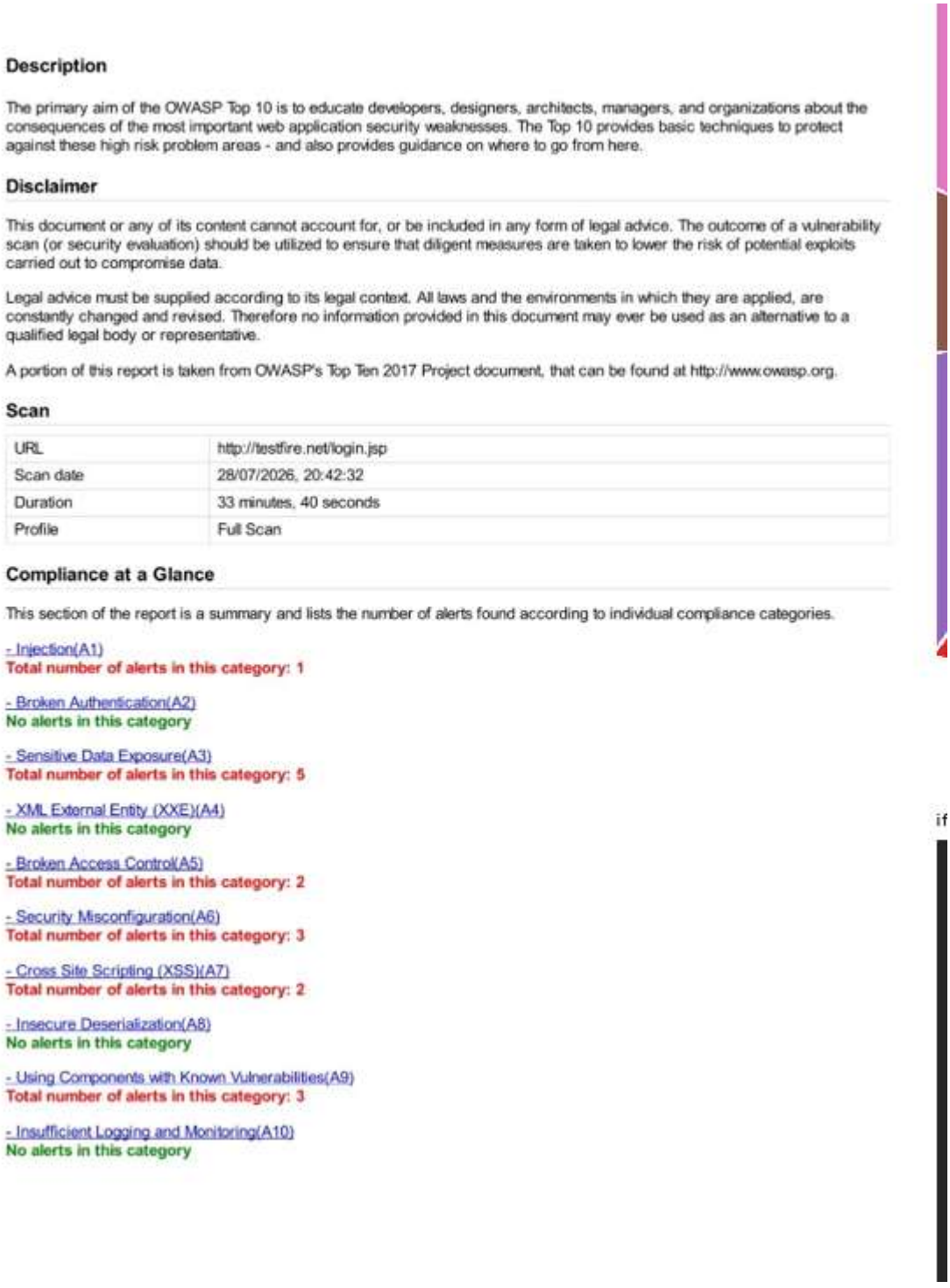
					restrict file access to an allowlisted directory.
F-04	Clickjacking – X-Frame-Options header missing	CVSS v2 6.8 shown; severity should be validated	CWE-693	The server response did not include the X-Frame-Options header according to the alert.	Set Content-Security-Policy frame-ancestors; add X-Frame-Options for legacy browser compatibility; test legitimate framing requirements.
F-05	Password type input with autocomplete enabled	CVSS v3 7.5 shown in evidence	CWE-200	The report flags browser autocomplete on a password input. Risk depends on device, browser and application context.	Review authentication form requirements; apply appropriate autocomplete attributes; use secure session handling and avoid storing credentials in unsafe contexts.
F-06	Broken links	Informational – CVSS 0.0 shown	CWE-16	The report lists inaccessible links. Multiple instances appear in the detailed report.	Repair or remove stale links; verify routing and resource availability; distinguish these observations from exploitable security vulnerabilities.

8. Finding Notes and Severity Interpretation

- CVSS values are reproduced from the screenshots and are not independently recalculated in this report.
- The Blind SQL Injection record shows CVSS v3 base score 10.0. Treat this as a high-priority validation item, not proof that exploitation was successfully demonstrated.
- The XSS and Directory Traversal records show CVSS v3 base score 5.3 in the supplied detailed pages.
- The clickjacking record shows CVSS v2 base score 6.8. CVSS v2 and v3 scores should not be compared as if they were generated under the same scoring version.
- The password-autocomplete record shows a CVSS v3 base score of 7.5 in the evidence; validate the exact alert context and affected form before assigning final risk.
- Broken links show CVSS 0.0 and are generally informational unless they expose sensitive resources or cause a separate security impact.

9. Evidence Register

Evidence images are inserted below in the order that best supports the assessment narrative. Captions describe what is visible in each supplied screenshot.



Description

The primary aim of the OWASP Top 10 is to educate developers, designers, architects, managers, and organizations about the consequences of the most important web application security weaknesses. The Top 10 provides basic techniques to protect against these high risk problem areas - and also provides guidance on where to go from here.

Disclaimer

This document or any of its content cannot account for, or be included in any form of legal advice. The outcome of a vulnerability scan (or security evaluation) should be utilized to ensure that diligent measures are taken to lower the risk of potential exploits carried out to compromise data.

Legal advice must be supplied according to its legal context. All laws and the environments in which they are applied, are constantly changed and revised. Therefore no information provided in this document may ever be used as an alternative to a qualified legal body or representative.

A portion of this report is taken from OWASP's Top Ten 2017 Project document, that can be found at http://www.owasp.org.

Scan

URL	http://testfire.net/login.jsp
Scan date	28/07/2026, 20:42:32
Duration	33 minutes, 40 seconds
Profile	Full Scan

Compliance at a Glance

This section of the report is a summary and lists the number of alerts found according to individual compliance categories.

- Injection(A1)
Total number of alerts in this category: 1

- Broken Authentication(A2)
No alerts in this category

- Sensitive Data Exposure(A3)
Total number of alerts in this category: 5

- XML External Entity (XXE)(A4)
No alerts in this category

- Broken Access Control(A5)
Total number of alerts in this category: 2

- Security Misconfiguration(A6)
Total number of alerts in this category: 3

- Cross Site Scripting (XSS)(A7)
Total number of alerts in this category: 2

- Insecure Deserialization(A8)
No alerts in this category

- Using Components with Known Vulnerabilities(A9)
Total number of alerts in this category: 3

- Insufficient Logging and Monitoring(A10)
No alerts in this category

Evidence 1 – ZAP compliance summary showing category alert counts.

Compliance According to Categories: A Detailed Report

This section is a detailed report that explains each vulnerability found according to individual compliance categories.

(A1)Injection

Injection flaws, such as SQL, NoSQL, OS, and LDAP injection, occur when untrusted data is sent an interpreter as part of a command or query. The attacker's hostile data can trick the interpreter into executing unintended commands or accessing data without proper authorization.

Total number of alerts in this category: 1

Alerts in this category

Blind SQL Injection

SQL injection (SQLi) refers to an injection attack wherein an attacker can execute malicious SQL statements that control a web application's database server.

CVSS2	Base Score: 6.8 Access Vector: Network_accessible Access Complexity: Medium Authentication: None Confidentiality Impact: Partial Integrity Impact: Partial Availability Impact: Partial Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CVSS3	Base Score: 10.0 Attack Vector: Network Attack Complexity: Low Privileges Required: None User Interaction: None Scope: Changed Confidentiality Impact: High Integrity Impact: High Availability Impact: None
CWE	CWE-89
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

(A2)Broken Authentication

Application functions related to authentication and session management are often implemented incorrectly, allowing attackers to compromise passwords, keys, or session tokens, or to exploit other implementation flaws to assume other users' identities.

No alerts in this category.

(A3)Sensitive Data Exposure

Evidence 2 – Detailed Blind SQL Injection alert and CVSS/CWE information

CVSS2	Base Score: 0.0 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: None Integrity Impact: None Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CVSS3	Base Score: 7.5 Attack Vector: Network Attack Complexity: Low Privileges Required: None User Interaction: None Scope: Unchanged Confidentiality Impact: High Integrity Impact: None Availability Impact: None
CWE	CWE-200
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

(A4)XML External Entity (XXE)

Many older or poorly configured XML processors evaluate external entity references within XML documents. External entities can be used to disclose internal files using the file URI handler, internal file shares, internal port scanning, remote code execution, and denial of service attacks.

No alerts in this category.

(A5)Broken Access Control

Restrictions on what authenticated users are allowed to do are often not properly enforced. Attackers can exploit these flaws to access unauthorized functionality and/or data, such as access other users' accounts, view sensitive files, modify other users' data, change access rights, etc.

Total number of alerts in this category: 2

Alerts in this category

Directory traversal

This script is possibly vulnerable to directory traversal attacks.

Directory Traversal is a vulnerability which allows attackers to access restricted directories and read files outside of the web server's root directory.

	Base Score: 6.8 Access Vector: Network_accessible Access Complexity: Medium Authentication: None Confidentiality Impact: Partial

Evidence 3 – Sensitive-data-related alert details and missing X-Frame-Options observation.

must be patched and upgraded in a timely fashion.

Total number of alerts in this category: 3

Alerts in this category

Broken links

A broken link refers to any link that should take you to a document, image or webpage, that actually results in an error. This page was linked from the website but it is inaccessible.

CVSS2	Base Score: 0.0 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: None Integrity Impact: None Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CWE	CWE-16
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

Broken links

A broken link refers to any link that should take you to a document, image or webpage, that actually results in an error. This page was linked from the website but it is inaccessible.

CVSS2	Base Score: 0.0 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: None Integrity Impact: None Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CWE	CWE-16
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

Broken links

Evidence 4 – Password autocomplete and related detailed alert metadata.

A broken link refers to any link that should take you to a document, image or webpage, that actually results in an error. This page was linked from the website but it is inaccessible.

CVSS2	Base Score: 0.0 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: None Integrity Impact: None Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CWE	CWE-16
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

(A7)Cross Site Scripting (XSS)

XSS flaws occur whenever an application includes untrusted data in a new web page without proper validation or escaping, or updates an existing web page with user-supplied data using a browser API that can create HTML or JavaScript. XSS allows attackers to execute scripts in the victim's browser which can hijack user sessions, deface web sites, or redirect the user to malicious sites.

Total number of alerts in this category: 2

Alerts in this category

Cross site scripting

Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts into a legitimate website or web application. XSS occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.

CVSS2	Base Score: 6.4 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: Partial Integrity Impact: Partial Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CVSS3	Base Score: 5.3 Attack Vector: Network Attack Complexity: Low Privileges Required: None User Interaction: None Scope: Unchanged

Evidence 5 – OWASP category details, including security-misconfiguration section.

	Confidentiality Impact: None Integrity Impact: Low Availability Impact: None
CWE	CWE-79
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

Cross site scripting

Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts into a legitimate website or web application. XSS occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.

CVSS2	Base Score: 6.4 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: Partial Integrity Impact: Partial Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CVSS3	Base Score: 5.3 Attack Vector: Network Attack Complexity: Low Privileges Required: None User Interaction: None Scope: Unchanged Confidentiality Impact: None Integrity Impact: Low Availability Impact: None
CWE	CWE-79
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

(A8)Insecure Deserialization

Insecure deserialization often leads to remote code execution. Even if deserialization flaws do not result in remote code execution, they can be used to perform attacks, including replay attacks, injection attacks, and privilege escalation attacks.

No alerts in this category.

(A9)Using Components with Known Vulnerabilities

Components, such as libraries, frameworks, and other software modules, almost always run with full privileges. If a vulnerable component is exploited, such an attack can facilitate serious data loss or server takeover. Applications using components with known vulnerabilities may undermine application defenses and enable a range of possible attacks and impacts.

Total number of alerts in this category: 3

Evidence 6 – Cross-Site Scripting alert details and CVSS information.

Alerts in this category

Broken links

A broken link refers to any link that should take you to a document, image or webpage, that actually results in an error. This page was linked from the website but it is inaccessible.

CVSS2	Base Score: 0.0 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: None Integrity Impact: None Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CWE	CWE-16
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

Broken links

A broken link refers to any link that should take you to a document, image or webpage, that actually results in an error. This page was linked from the website but it is inaccessible.

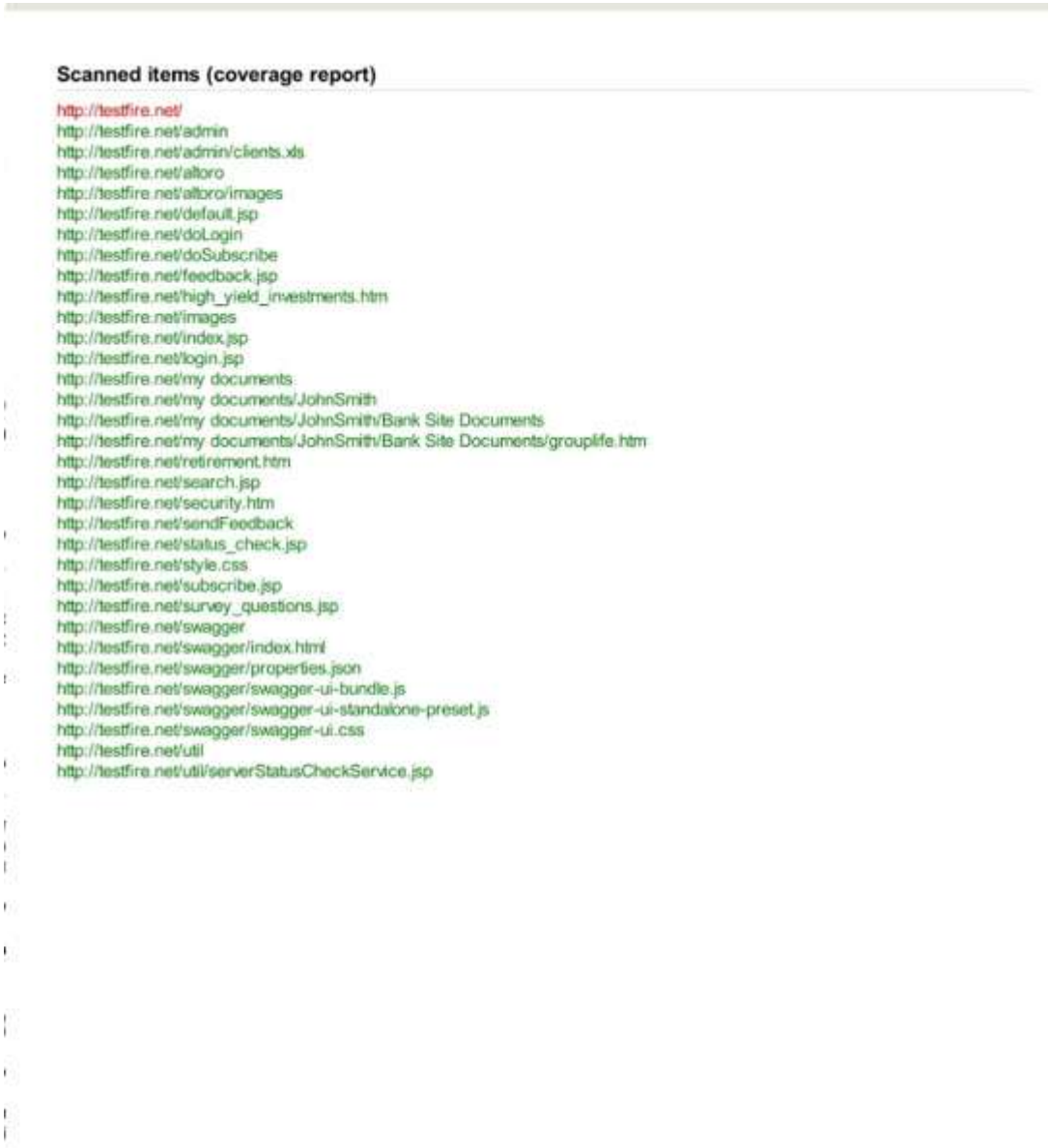
CVSS2	Base Score: 0.0 Access Vector: Network_accessible Access Complexity: Low Authentication: None Confidentiality Impact: None Integrity Impact: None Availability Impact: None Exploitability: Not_defined Remediation Level: Not_defined Report Confidence: Not_defined Availability Requirement: Not_defined Collateral Damage Potential: Not_defined Confidentiality Requirement: Not_defined Integrity Requirement: Not_defined Target Distribution: Not_defined
CWE	CWE-16
Affected item	**Web Server**
Affected parameter	
Variants	Not available in the free trial

Broken links

A broken link refers to any link that should take you to a document, image or webpage, that actually results in an error. This page was linked from the website but it is inaccessible.

	Base Score: 0.0 Access Vector: Network_accessible

Evidence 7 – Further XSS details and categories with no alerts.



Evidence 8 – Broken-link alert instances and associated metadata.

Scanned-items coverage report listing discovered application URLs.

10. Remediation Roadmap

Priority	Action	Suggested owner	Verification
P1 – Immediate	Manually validate Blind SQL Injection; remediate with parameterized queries and least-privilege database access.	Application developer / DBA	Retest relevant input paths; confirm injected input is treated as data.
P1 – High	Review password field autocomplete behavior and authentication/session design.	Application developer	Inspect response/form behavior and confirm credentials are not exposed through unsafe storage.
P2 – High	Fix directory traversal risk using strict path allowlisting and canonicalization.	Application developer	Test traversal payload handling in an authorized staging environment.
P2 – Medium	Fix XSS by applying context-	Application developer	Retest affected parameters and

	aware output encoding and safe templating.		verify input is rendered as text.
P2 – Medium	Add frame protection using CSP frame-ancestors and compatible X-Frame-Options policy.	Web administrator	Inspect HTTP response headers and test framing policy.
P3 – Low	Resolve broken links and verify application routes/resources.	Web administrator / QA	Crawl affected pages and confirm links return expected responses.

11. Limitations

- This report is based on screenshots rather than the original ZAP HTML/XML export; some alert names, URLs, parameters and evidence details may not be visible.
- The compliance summary uses OWASP Top 10 category labels and reports 16 alerts. This number is not the number of unique vulnerability classes.
- The supplied screenshots do not demonstrate successful exploitation of every alert.
- Some alerts are duplicated across scanned pages or endpoints; duplicates should be consolidated during final triage.
- No source-code review, authenticated role comparison, manual exploit validation or remediation retest evidence was supplied.
- The scan date/time is transcribed as 28 July 2026, 20:42:32, and the duration as 33 minutes, 40 seconds, as shown in the scan summary.

12. Conclusion

The OWASP ZAP assessment identified 16 category-level alerts across the supplied OWASP Top 10 compliance summary. The detailed evidence highlights several issues that warrant attention, particularly the Blind SQL Injection alert, XSS, Directory Traversal, missing frame-protection headers and password autocomplete configuration. Broken-link observations should be handled as a separate quality/informational workstream unless further testing demonstrates a security impact. The next step is to validate each important alert manually, remediate confirmed weaknesses, and perform a follow-up scan to verify that the fixes are effective.

13. References

- OWASP Zed Attack Proxy (ZAP) – https://www.zaproxy.org/
- OWASP Top 10 – https://owasp.org/www-project-top-ten/
- OWASP Cross Site Scripting Prevention Cheat Sheet – https://cheatsheetseries.owasp.org/
- OWASP SQL Injection Prevention Cheat Sheet – https://cheatsheetseries.owasp.org/
- Common Weakness Enumeration (CWE) – https://cwe.mitre.org/
- Common Vulnerability Scoring System (CVSS) – https://www.first.org/cvss/

APPENDIX A

SUPPLEMENTARY DOMAIN RECONNAISSANCE & NETWORK ENUMERATION

Additional evidence for testfire.net • Captured 02 November 2026

This appendix adds the supplied DNS, domain-intelligence, Nmap and traceroute screenshots as supplementary reconnaissance evidence. These observations are separate from the OWASP ZAP application alerts documented in the main report. They do not change the ZAP alert count or prove that any service is exploitable. The screenshots identify testfire.net and the resolved address 65.61.137.117.

A.1 Evidence 9 – DNS Records and IP Intelligence

Screenshot transcription (visible values):
Resolved IP address: 65.61.137.117
DNS records/hostnames: asia3.akam.net.; eur5.akam.net.; usc3.akam.net.; ns1-99.akam.net.; ns1-206.akam.net.; eur2.akam.net.; usc2.akam.net.; usw2.akam.net.
WHOIS privacy: Enabled – tool labels this as Medium Risk.
IP intelligence response: status=success; country=United States; country code=US; region=TX (Texas); city=Allen; ZIP=75013; timezone=America/Chicago; ISP=Rackspace Hosting; organization=Rackspace Backbone Engineering; ASN/AS=AS33070 Rackspace Hosting.

Interpretation: The screenshot associates testfire.net's resolved address with Rackspace hosting and displays several Akamai nameservers. IP geolocation and provider attribution are third-party intelligence estimates and can describe hosting infrastructure rather than the application operator's physical location. WHOIS privacy is a registration-privacy feature; by itself it is not evidence of a vulnerability.

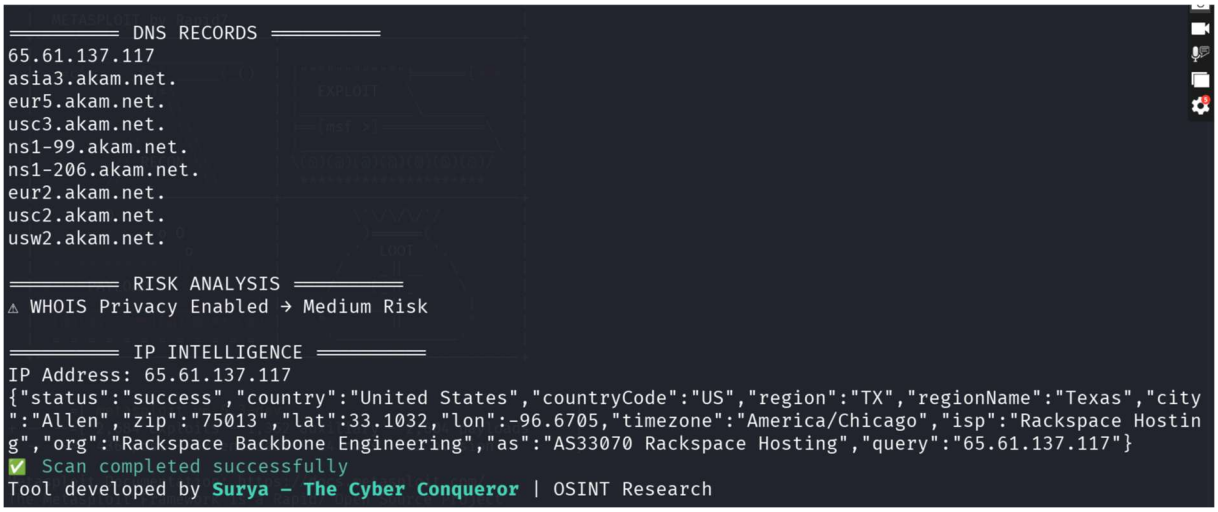


Figure A-1. DNS records, WHOIS privacy status and IP intelligence output.

A.2 Evidence 10 – Domain Overview, Age and HTTP Response Headers

Screenshot transcription (visible values):
Domain name: testfire.net; domain length: 12 characters; top-level domain: .net; likely domain type: Commercial / Brand.
Creation date shown: 1999-07-23T13:52:32Z; domain age shown by the tool: 27 years.
HTTPS support: Enabled.
HTTP response: HTTP/1.1 200 OK; Server: Apache-Coyote/1.1; Set-Cookie: JSESSIONID=...; Path=/; HttpOnly; Content-Type: text/html;charset=ISO-8859-1; Transfer-Encoding: chunked.
The screenshot also displays a response Date header of Mon, 02 Nov 2026 06:05:50 GMT and an infrastructure summary of resolved IP 65.61.137.117, likely Cloud / CDN.

Interpretation: The response indicates that the page returned HTTP 200 at the time represented in the screenshot and that the server identified itself as Apache-Coyote/1.1. The JSESSIONID cookie is marked HttpOnly, which helps prevent client-side scripts from reading that cookie. The screenshot does not show the Secure or SameSite attributes, so their presence cannot be confirmed from this evidence. HTTPS being enabled does not, by itself, establish that the TLS configuration is secure.

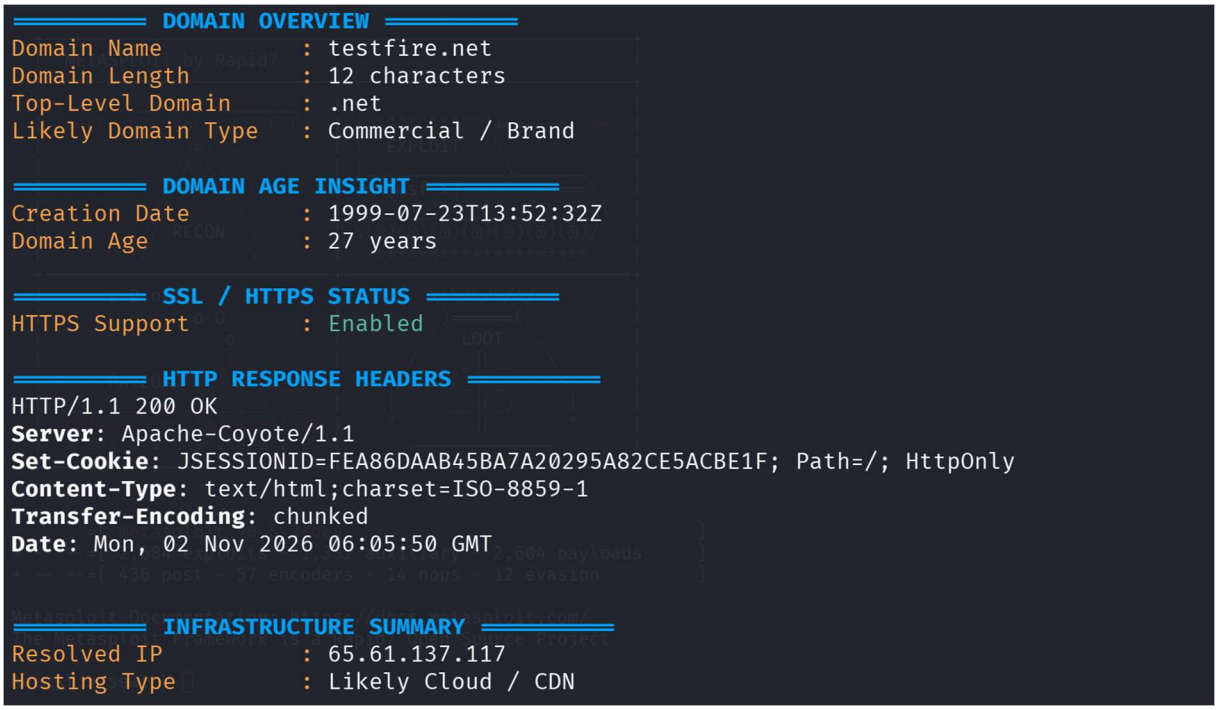


Figure A-2. Domain overview, HTTPS status and HTTP response headers.

A.3 Evidence 11 – Nmap Service and Version Detection

Command shown: nmap -A testfire.net

Screenshot transcription (visible output):
Nmap version: 7.991; target: testfire.net (65.61.137.117); host is up with 0.27 s latency; 996 TCP ports are reported filtered (no response).
80/tcp – open – http – Apache Tomcat/Coyote JSP engine 1.1; HTTP title: Altoro Mutual; HTTP server header: Apache-Coyote/1.1.
443/tcp – open – ssl/http – Apache Tomcat/Coyote JSP engine 1.1; certificate subject common name: demo.testfire.net; subject alternative name: DNS:demo.testfire.net; certificate validity shown: 21 May 2025 to 21 June 2026.
8080/tcp – open – http – Apache Tomcat/Coyote JSP engine 1.1; Nmap reports that a proxy might be redirecting requests; HTTP title: Altoro Mutual.
8443/tcp – closed – https-alt.

Interpretation: The scan identifies three open TCP services (80, 443 and 8080) and one closed service (8443) among the displayed results. The service/version strings and page title are fingerprinting observations, not proof of a specific weakness. The certificate's displayed expiry date is 21 June 2026; because the screenshot is dated 02 November 2026, the certificate appears expired at the time of capture. Confirm this with a fresh TLS inspection before treating it as a current finding. The command uses Nmap's -A option, which enables advanced detection features; only the results visible in the screenshot are transcribed here.

```
┌──(root㉿kali)-[~]
└─# nmap -A testfire.net
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-02 01:03 -0500
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.27s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE   VERSION
80/tcp   open   http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp  open   ssl/http  Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
|_ssl-date: 2026-11-02T06:04:45+00:00; +1s from scanner time.
|_http-title: Altoro Mutual
8080/tcp open   http      Apache Tomcat/Coyote JSP engine 1.1
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8443/tcp closed https-alt
```

Figure A-3. Nmap -A output showing detected ports, services, HTTP metadata and certificate dates.

A.4 Evidence 12 – Traceroute Path

Screenshot transcription (visible hops):
Traceroute is shown as using port 8443/tcp. Hop 1: 192.168.29.1 (3.02 ms); hop 2: 10.218.16.1 (7.70 ms); hop 3: 172.16.5.10 (5.26 ms); hop 4: 192.168.247.204 (5.11 ms); hop 5: 192.168.230.212 (6.09 ms); hop 6: 192.168.230.195 (7.39 ms); hop 7: 192.168.59.112 (7.40 ms). Hops 8–9 are displayed as non-responses. Hop 10: 103.198.140.116 (20.89 ms); hop 11: 49.45.4.85 (275.32 ms); hop 12: 49.45.4.103 (274.81 ms). Hop 13 is displayed as a non-response. Hops 14–19 traverse Cogent network hostnames; hops 20–22 show Rackspace network hostnames; hop 23 shows 74.205.108.61 (core9-aggr171a-8.dfw3.rackspace.net), with approximately 295.88 ms RTT.

Interpretation: The route output shows the path observed from the scanning network toward the target, including intermediate private-address hops and later Cogent/Rackspace-labelled hops. Asterisks/non-responses at intermediate hops do not necessarily indicate a fault; routers may filter or deprioritize traceroute probes. Latency values are specific to the capture time and network path and should not be treated as stable performance measurements.

```
TRACEROUTE (using port 8443/tcp)
HOP RTT       ADDRESS
1   3.02 ms   reliance.reliance (192.168.29.1)
2   7.70 ms   10.218.16.1
3   5.26 ms   172.16.5.10
4   5.11 ms   192.168.247.204
5   6.09 ms   192.168.230.212
6   7.39 ms   192.168.230.195
7   7.40 ms   192.168.59.112
8   ... 9
10  20.89 ms  103.198.140.116
11  275.32 ms 49.45.4.85
12  274.81 ms 49.45.4.103
13  ...
14  273.81 ms be3359.ccr42.lax01.atlas.cogentco.com (154.54.3.69)
15  273.38 ms be2932.ccr32.phx01.atlas.cogentco.com (154.54.45.161)
16  272.56 ms be5471.ccr21.elp02.atlas.cogentco.com (154.54.166.57)
17  271.96 ms be3846.ccr32.dfw01.atlas.cogentco.com (154.54.165.29)
18  260.48 ms te0-17-0-5-5.ccr41.dfw03.atlas.cogentco.com (38.122.39.81)
19  297.48 ms te0-17-0-5-5.ccr41.dfw03.atlas.cogentco.com (38.122.39.81)
20  297.00 ms corec-dcpe3.dfw1.rackspace.net (148.62.41.97)
21  296.66 ms core10-corec.dfw1.rackspace.net (148.62.41.135)
22  296.27 ms core10-corec.dfw1.rackspace.net (148.62.41.135)
23  295.88 ms core9-aggr171a-8.dfw3.rackspace.net (74.205.108.61)
```

Figure A-4. Traceroute output showing the visible network hops toward the target.

A.5 Consolidated Supplementary Observations

Area	Observation
DNS / IP	testfire.net resolved to 65.61.137.117; displayed IP intelligence attributes the address to Rackspace in Allen, Texas.
Name servers	Multiple Akamai nameservers are listed in the DNS output.
Web response	HTTP 200 OK; Apache-Coyote/1.1; JSESSIONID cookie shown with HttpOnly.
Open TCP ports	80, 443 and 8080 were reported open; 8443 was reported closed.
TLS certificate	The Nmap screenshot shows a certificate for demo.testfire.net with a not-after date of 21 June 2026.
Network path	Traceroute output reaches Rackspace-labelled network hops; some intermediate hops do not respond.

A.6 Scope and Validation Note

These screenshots are supplementary reconnaissance evidence and are not OWASP ZAP alert records. The main report's 16-alert ZAP compliance summary remains unchanged. Before presenting any of these observations as confirmed security findings, repeat the checks with authorization, retain the raw Nmap and HTTP/TLS outputs, verify the current DNS and certificate state, and manually validate the affected service. The IP-geolocation result, server banner and traceroute path are contextual intelligence rather than vulnerabilities on their own.

FINAL RECOMMENDATIONS

Prioritized remediation and verification plan

1. Immediate and high-priority actions

1. Validate the Blind SQL Injection alert in an authorized test environment. If confirmed, use parameterized queries or prepared statements, validate input on the server, apply least-privilege database accounts and return safe error messages.

2. Review the password form and authentication/session handling. Confirm that credentials are transmitted only over HTTPS, session identifiers are protected, and browser autocomplete behavior matches the application's security and usability requirements. The supplied response shows HttpOnly for JSESSIONID, but Secure and SameSite were not visible and should be checked.

3. Recheck the TLS certificate shown by Nmap. The captured certificate for demo.testfire.net has a not-after date of 21 June 2026, earlier than the 02 November 2026 capture date. Renew or replace it if a fresh inspection confirms it is expired, and verify the full certificate chain, hostname, protocol versions and cipher configuration.

2. Web application security improvements

4. Prevent Cross-Site Scripting (XSS) by applying context-aware output encoding, safe templating and server-side input validation. Consider a restrictive Content-Security-Policy as an additional defence, then retest the affected pages and parameters.

5. Address Directory Traversal by avoiding filesystem paths built directly from user input. Canonicalize and validate paths, restrict file access to approved directories, and use allowlists for permitted files and locations.

6. Add clickjacking protection. Configure Content-Security-Policy frame-ancestors and, where legacy browser support is required, a compatible X-Frame-Options header. Verify that legitimate framing use cases continue to work.

7. Review HTTP security headers and cookie attributes. Confirm whether Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options and Referrer-Policy are appropriate for the site. For session cookies, assess Secure and SameSite in addition to the HttpOnly attribute visible in the supplied screenshot.

3. Infrastructure and service-hardening improvements

8. Review exposed services on TCP ports 80, 443 and 8080. Confirm that each is required for the application. Restrict administrative or non-public services through firewall rules or network segmentation, and disable unused listeners. Specifically review whether port 8080 must be reachable from untrusted networks.

9. Verify the Apache Tomcat/Coyote service identification and patch level. Apply supported security updates, remove obsolete components, review proxy configuration, and avoid disclosing unnecessary server-version details in public response headers where feasible.

10. Review DNS and domain configuration. Keep authoritative DNS records accurate, restrict unauthorized zone transfers, monitor unexpected DNS changes and consider DNSSEC where supported by the domain's DNS provider. The listed Akamai nameservers and Rackspace IP attribution are contextual observations, not vulnerabilities by themselves.

11. Treat the traceroute output as network-path context rather than a security finding. Investigate unexpected routing only if it conflicts with the approved network architecture; intermediate non-responses alone do not establish a fault.

12. Repair broken links identified by the ZAP report and verify that affected routes and resources return the expected responses. Track these separately as quality or availability issues unless testing demonstrates a security impact.

4. Verification and retesting checklist

- Obtain authorization and confirm the exact assessment scope before retesting.
- Repeat DNS, HTTP-header, TLS, Nmap and traceroute checks and save timestamped raw outputs.
- Manually validate high-impact ZAP alerts in a controlled test environment.
- Record each confirmed issue with its affected URL, parameter or service, evidence and business impact.
- Apply fixes in a staging environment and run targeted regression tests.

- Run a new OWASP ZAP scan and compare alert counts and individual findings with the baseline.
- Confirm that resolved findings no longer reproduce; document accepted risks and false positives.
- Store evidence securely and redact session identifiers, tokens, credentials and other sensitive data.

5. Overall recommendation

Prioritize manual validation of the Blind SQL Injection alert, review the password form and authentication/session controls, and verify the apparently expired TLS certificate. Next, address XSS, Directory Traversal and frame-protection configuration, then harden exposed services and complete the broken-link and DNS reviews. Perform a documented retest after remediation. Do not describe scanner alerts or reconnaissance observations as confirmed exploitable vulnerabilities unless manual validation supports that conclusion.

Assessment note: These recommendations are based on the supplied OWASP ZAP report and the four supplementary reconnaissance screenshots. They are guidance for an authorized educational assessment; current service state must be independently.

END OF REPORT